

Data Protection Policy

Introduction

The Department for the Economy (DfE) is fully committed to complying with the Data Protection Act 2018 (DPA) which introduces stricter requirements than the 1998 Act; ensures the standards set out in the General Data Protection Regulation (GDPR) have effect in the UK; and, ensures the Law Enforcement Directive is also implemented into UK law.

We will follow procedures to ensure that all employees, contractors, agents, consultants and other parties who have access to any personal data held by or on behalf of us are fully aware of, and abide by, their duties and responsibilities under the Act.

Statement of Policy

We need to collect and use the personal data of a wide range of people in order to carry out our business and provide our services. These may include members of the public, current, past and prospective employees, clients, customers and suppliers. In addition, we may be required by law to collect and use personal information. All personal information, however it is collected, recorded and used, and whether it is on paper, in electronic records or recorded in other formats, on other media, or by any other means must be handled and dealt in line with the Act

Data Protection Principles

We fully support and comply with the six principles of the GDPR which are embedded in the Act. This means that personal information must be:

1. Processed lawfully, fairly and in a transparent manner in relation to individuals;
2. Collected for specified, explicit and legitimate purposes and not further processed in a manner that is incompatible with those purposes;
3. Adequate, relevant and limited to what is necessary in relation to the purposes for which they are processed;
4. Accurate and, where necessary, kept up to date; every reasonable step must be taken to ensure that personal data that are inaccurate, having regard to the purposes for which they are processed, are erased or rectified without delay;
5. Kept in a form which permits identification of data subjects for no longer than is necessary for the purposes for which the personal data are processed; and
6. Processed in a manner that ensures appropriate security of the personal data, including protection against unauthorised or unlawful processing and against accidental loss, destruction or damage, using appropriate technical or organisational measures.

We will take responsibility for compliance with these principles in all areas of our work, and for being able to demonstrate compliance through a variety of ways,

Our purpose for holding personal information, and a general description of the categories of people and organisations to which we may disclose it, are listed on the [Information Commissioner's Data Protection Register](#). DfE's entry number is Z6144919.

Handling of Personal Information

All our employees will take responsibility for the following through appropriate training and good management practices:

- Fully observe the bases in Article 6 (and Article 9(2)) regarding the lawful collection and use of personal information in the case of special category data as defined by the GDPR;
- Meet our legal obligations to specify the Department's lawful basis for processing and the purposes for which all personal information is used, and to make this available to those whose data is collected ;
- Collect and process appropriate personal information only to the extent that it is needed to fulfil operational needs or to comply with any legal requirements;
- Ensure the quality, and accuracy of personal information used;
- Apply strict checks to determine the length of time personal information is held and ensure that this period of time is reflected in the Department's Retention & Disposal Schedule;
- Ensure that the rights of people about whom information is held can be fully exercised under the Act; and
- Take appropriate technical and organisational security measures to safeguard personal information.

Compliance

We will ensure that:

- There is always a Data Protection Officer with specific responsibility for data protection in DfE tasked with: promoting accountability and governance; informing and advising us on our obligations, monitoring compliance, training staff, and co-operating with the Information Commissioner's Office;
- Relevant documentation on processing activities is maintained.
- Everyone managing and handling personal data is appropriately trained to do so and that awareness of the Act is raised amongst all employees annually.
- Everyone managing and handling personal information understands that they are directly and personally responsible for following the good practice set out in the Information Commissioner's guidance and Codes of Practice;
- Only employees who need access to personal data as part of their duties are authorised to do so;
- Everyone managing and handling personal data is appropriately supervised;
- Anyone wanting to make enquiries about handling personal data knows what to do;
- Queries about handling personal data are dealt with promptly and courteously;
- Methods of handling personal data are clearly described and recorded;

- Where data processors are used, a written contract will be in place that meets all necessary legislative requirements;
- A regular review and audit is made of the way personal data is managed;
- Methods of handling personal data are regularly assessed and evaluated; and
- The handling of personal data is regularly assessed.

To assist in achieving compliance, we have:

- Appointed a Data Protection Officer as required by GDPR;
- A Senior Information Risk Owner in place as the officer with overall risk responsibility for all personal data processed by DfE;
- Information Asset Owners in place as officers with overall responsibility for all the personal data processed by their business areas;
- A Departmental Information Manager in place as the officer with delegated responsibility for records and information management within DfE;
- Dedicated Local Information Managers in place in each of our business areas to ensure staff compliance with the data protection principles.
- Produced this policy and associated policy and procedures;
- Introduced mandatory data protection impact assessments for any new, or changes to current, projects / policy that involve the processing of personal data, all new software systems or any departmental or inter-departmental re-structuring project; and

Employee Responsibilities

All employees have a responsibility to protect the personal data held by DfE.

Employees will take steps to ensure that personal data is kept secure at all times against unauthorised or unlawful loss or disclosure and, in particular, will ensure that:

- They are trained appropriately in the handling of personal data;
- Paper files and other records or documents containing personal or special category data are kept in a secure environment;
- Personal data held electronically is protected by the use of secure network passwords which are renewed periodically and that access controls are set appropriately for personal data held in our electronic document and record management system;
- Personal data accidentally accessed is reported immediately to line management and the Data Protection Officer;
- Individual passwords are not easily compromised; and
- Where personal information is held on a laptop or other portable device, sufficient encryption will be used in case the device is lost or stolen. Separate policies govern the appropriate use and security of portable devices.

If and when employees collect information about other people as part of their responsibilities, they must comply with all data protection requirements. No one should access or disclose personal data inappropriately or use personal data held about others for their own purposes. The Data Protection Act provides for the

prosecution of officers where an offence is proved to have been committed with their consent, connivance, or due to their neglect.

Disclosure of Personal Information

Strict conditions apply to the passing of personal information [to others](#) both internally and externally. We will not disclose personal information to any third party unless we believe it is fair and lawful to do so. Confidentiality will be respected, where appropriate.

In certain circumstances, information relating to employees acting in a business capacity may be made available provided:

- We have the statutory power or are required by law to do so; or
- The information is clearly not of a nature to intrude on their personal privacy; or
- The employee has consented to the disclosure; or
- The information is in a form that does not identify individual employees.

Third Party Users of Personal Information

Any third parties who are users of personal data supplied by DfE will be required to confirm and demonstrate that they will abide by the data protection requirements. Audits may be carried out by DfE to ensure compliance.

Policy Awareness

Awareness of all Departmental Policy surrounding personal data will be achieved by the following means:

- All employees will be advised of the data protection policy statement by DfE's Senior Information Risk Owner, and will be required to confirm that they have read and understood it;
- The policy statement will be posted on our intranet and internet web-sites, as will any subsequent revisions;
- Line managers will provide all new employees with a copy of the policy statement during induction, and will require them to confirm that they have read and understood it; and
- Business areas which process personal information using any third parties will make them aware of the policy statement and ensure their compliance with it.

Policy Review

This policy will be reviewed on an annual basis.

May 2018